



CLIENT DELIVERABLE

SAOS Compliance & Trust Center v1.0

Systack Documentation

Table of Contents

SAOS Compliance & Trust Center

Security Posture

Compliance Policies

Customer Rights

Data Export

Trust Center API

ROLE	COLOR	HEX
Headers, CTAs	Navy	 #001a2d
Navy Light	Navy Light	 #002845
Secondary accents	Teal	 #007da9
Primary buttons, links	Cyan	 #00a1db
Gradients	Cyan Bright	 #00c5e0
Backgrounds	Gray 50	 #f8fafc
Cards	Gray 100	 #f1f5f9
Borders	Gray 200	 #e2e8f0
Muted text	Gray 400	 #94a3b8
Body text	Gray 600	 #475569
Headings	Gray 800	 #1e293b
Success	Green	 #22c55e
Error	Red	 #ef4444
Accent highlights	Purple	 #8b5cf6

SAOS Compliance & Trust Center

Version: 1.0
Date: 2026-07-05
Status: Active

Security Posture

CONTROL	STATUS	DETAILS
Multi-Factor Authentication	✔ Available	TOTP RFC 6238, Google Authenticator compatible
Role-Based Access Control	✔ Active	5 roles: customer, support, billing, ops, admin
Rate Limiting	✔ Active	Per-endpoint, 8 configurations
Audit Logging	✔ Active	Full audit trail, 3-year retention
Encryption in Transit	✔ Active	TLS 1.3 via Tailscale WireGuard
Encryption at Rest	✔ Active	AES-256 filesystem encryption
Network Security	✔ Active	Tailscale mesh VPN — no public exposure
Data Residency	✔ Active	United States (Dallas, TX)
Backup Verification	✔ Active	Daily pg_dump + restore drill
Security Monitoring	✔ Active	Event tracking, threat detection
Incident Response	✔ Active	P1-P4 severity, 15min-4hr response

Compliance Policies

1. Information Security Policy

- All systems require authentication (PIN + optional MFA)
- RBAC enforced across all endpoints
- Rate limiting on all authentication endpoints
- All access events logged

2. Data Retention Policy

DATA TYPE	RETENTION	ACTION
Client account	Active + 90 days	Auto-delete
Task history	2 years	Archive
Chat messages	1 year	Archive
Audit logs	3 years	Archive

DATA TYPE	RETENTION	ACTION
Security events	3 years	Archive
Deliverables	Active + 30 days	Auto-delete
Usage metrics	13 months	Auto-delete
Backups	30 days rolling	Auto-rotate

3. Incident Response Procedure

SEVERITY	DESCRIPTION	RESPONSE TIME
P1	Critical — breach, outage	15 minutes
P2	High — partial outage	1 hour
P3	Medium — degraded	4 hours
P4	Low — minor	Next business day

4. Privacy & Data Protection

- Customers own their data — Systack is custodian
- Data export available at any time (JSON/ZIP)
- No data shared with third parties
- No data sold or used for advertising
- AI processing on local infrastructure only

5. Access Control Policy

- PIN authentication required
- MFA recommended for all users
- 5-tier RBAC: customer → support → billing → ops → admin
- Internal API keys for system-to-system auth
- All credential changes logged

Customer Rights

- **Right to Access:** Full data export via dashboard
- **Right to Correction:** Update via dashboard or support
- **Right to Deletion:** Request account deletion (30-day purge)
- **Right to Portability:** JSON/ZIP export format

Data Export

Customers can export all their data at any time: - `POST /api/export/data` — ZIP containing tasks, chat, deliverables, settings - No admin intervention required - Export logged to audit trail

Trust Center API

- GET `/api/compliance/trust-center` — Public endpoint (no auth required)
- Returns security posture, active policies, recent incidents, backup status

Last updated: 2026-07-05 by SOL. Questions: contact@systack.net